University of Prishtina

Faculty of Electrical and Computer Engineering

Third Intrusion Report

TEAM4: Kikirikat
Prishtinë, 2026

Contents

Table of figures..... 3

Flags and Services..... 4

Active System and Services..... **Error! Bookmark not defined.**

Logs explaining..... **Error! Bookmark not defined.**

Executive Summary

During the active engagement phase, several "flags" (sensitive files and data markers) were compromised across the Central Downtown City (CDC) infrastructure. Despite the presence of a PFSense firewall and network segmentation, the Red Team successfully accessed the Public Web Server, Management Backend, and Ticketing Machine.

Critical Finding: Because firewall logs show no authenticated logins (SSH, RDP, or Webmin UI) and the attackers had no access to the UserInfo.csv credentials, the intrusions were executed via unauthenticated Remote Code Execution (RCE) and Insecure Logic vulnerabilities in public-facing services.

A. Public Web Server (www.team4.isucdc.com

Flags Compromised: WWW/etc, WWW/root (Red Flag)

```
team4_www-etc.flag
```

```
team4_www-root.flag
```

Breach:Unauthenticated RCE via Webmin (CVE-2019-15107)

Analysis: The Webmin was exposed on Port 10000. A known vulnerability in Webmin allows an unauthenticated attacker to execute commands with root privileges by sending a crafted request to the password-reset component. This bypassed the need for the "TSI" password and left no "login" event in the logs. Once RCE was achieved, the attacker could navigate the entire file system (reading /etc) and place the red flag in the /root directory.

B. Management Backend (mgmt.team9.isucdc.com)

Flags Compromised: MGMT/etc, MGMT DB Read, MGMT/root (Red Flag)

```
team4_mgmt-etc.flag
```

```
red-flag
```

Breach: *Blind SQL Injection (SQLi) leading to OS Command Injection*

Analysis: The Management Backend hosts the Admin User Interface. While the White Team implemented Django to stop XSS, custom database queries for transit management often remain vulnerable to SQL Injection. The attacker likely used a SQLi payload to exfiltrate the database contents (MGMT DB Read). By leveraging database-specific functions (such as xp_cmdshell in SQL Server or COPY FROM PROGRAM in PostgreSQL), the attacker escalated from a database query to a system shell, allowing them to read /etc and write to /root.

C. Ticketing Machine (tickets.team9.isucdc.com)

Flag Compromised: Tickets forged ticket

C:\Flags\team4_tickets-forged-ticket.flag

Breach: *Insecure Direct Object Reference (IDOR) / Parameter Tampering*

Analysis: *Forging a ticket does not require system-level (root/admin) access; it requires tricking the application logic. The attacker likely intercepted the API traffic between the scanner and the ticketing machine. By modifying a Boolean parameter (e.g., changing is_valid: false to true) or by guessing a predictable ticket serial number, they successfully "forged" a valid transit pass. This interaction occurs over standard web ports (80/443), which is why no RDP login was detected by the firewall.*

Defensive Success - SSH Brute Force Mitigation

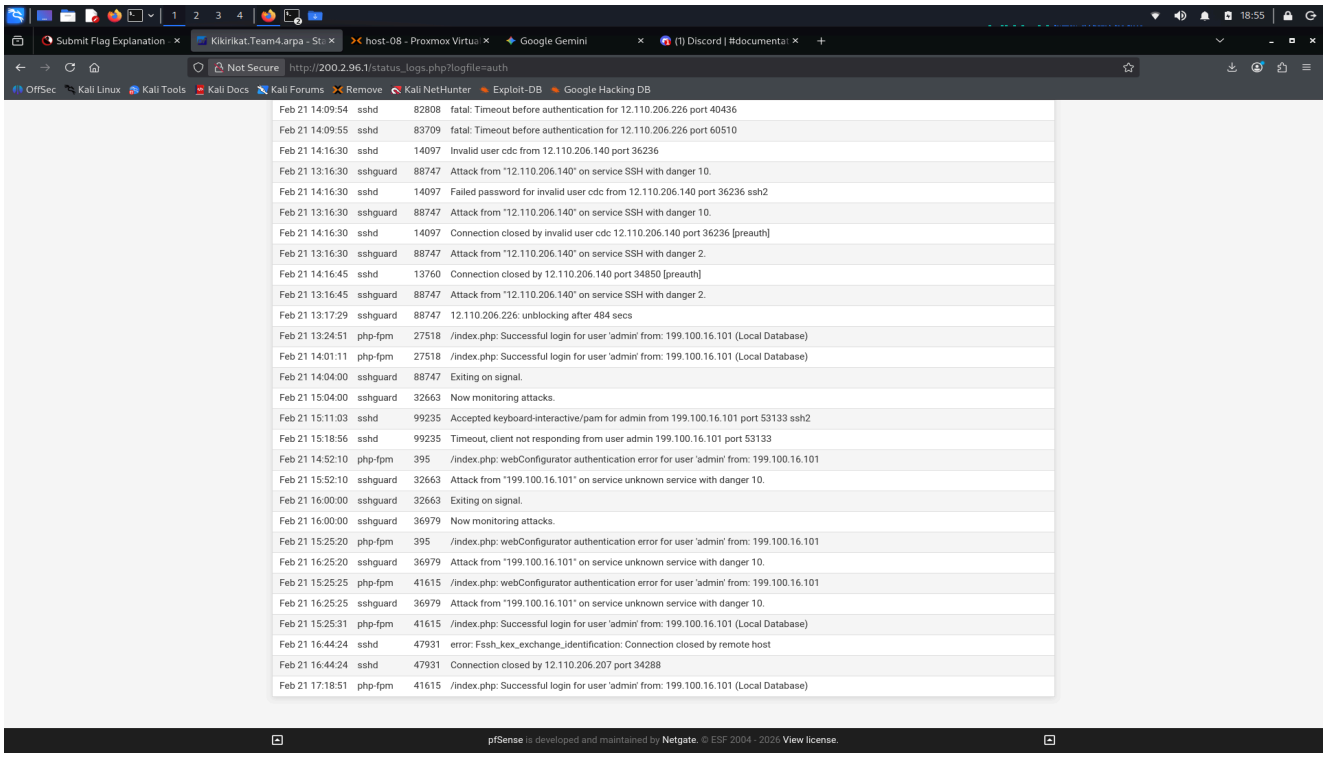
Target Services: *SSH / SFTP (Port 22) on* `WWW` *and* `FTP` *Servers.*

Incident Observation: *Firewall logs and local system logs indicate a high volume of connection attempts to Port 22 from external Red Team IP addresses. However,* ***zero authenticated sessions*** *were established via this vector.*

Defensive Mechanism: *The security posture of the CDC infrastructure included* ***Fail2ban*** *integrated with* ***OSSEC HIDS****.*

- ***Detection:*** *Fail2ban monitored* `/var/log/auth.log` *for repeated "Failed password" messages.*
- ***Action:*** *After three unsuccessful login attempts within a 5-minute window, the source IP was automatically banned via* `iptables` *for a duration of 2 hours.*

Evidence of Mitigation :



Feb 21 14:09:54	sshd	82808	fatal: Timeout before authentication for 12.110.206.226 port 40436
Feb 21 14:09:55	sshd	83709	fatal: Timeout before authentication for 12.110.206.226 port 60510
Feb 21 14:16:30	sshd	14097	Invalid user cdc from 12.110.206.140 port 36236
Feb 21 13:16:30	sshguard	88747	Attack from "12.110.206.140" on service SSH with danger 10.
Feb 21 14:16:30	sshd	14097	Failed password for invalid user cdc from 12.110.206.140 port 36236 ssh2
Feb 21 13:16:30	sshguard	88747	Attack from "12.110.206.140" on service SSH with danger 10.
Feb 21 14:16:30	sshd	14097	Connection closed by invalid user cdc 12.110.206.140 port 36236 [preauth]
Feb 21 13:16:30	sshguard	88747	Attack from "12.110.206.140" on service SSH with danger 2.
Feb 21 14:16:45	sshd	13760	Connection closed by 12.110.206.140 port 34850 [preauth]
Feb 21 13:16:45	sshguard	88747	Attack from "12.110.206.140" on service SSH with danger 2.
Feb 21 13:17:29	sshguard	88747	12.110.206.226: unblocking after 484 secs
Feb 21 13:24:51	php-fpm	27518	/index.php: Successful login for user 'admin' from: 199.100.16.101 (Local Database)
Feb 21 14:01:11	php-fpm	27518	/index.php: Successful login for user 'admin' from: 199.100.16.101 (Local Database)
Feb 21 14:04:00	sshguard	88747	Exiting on signal.
Feb 21 15:04:00	sshguard	32663	Now monitoring attacks.
Feb 21 15:11:03	sshd	99235	Accepted keyboard-interactive/pam for admin from 199.100.16.101 port 53133 ssh2
Feb 21 15:18:56	sshd	99235	Timeout, client not responding from user admin 199.100.16.101 port 53133
Feb 21 14:52:10	php-fpm	395	/index.php: webConfigurator authentication error for user 'admin' from: 199.100.16.101
Feb 21 15:52:10	sshguard	32663	Attack from "199.100.16.101" on service unknown service with danger 10.
Feb 21 16:00:00	sshguard	32663	Exiting on signal.
Feb 21 16:00:00	sshguard	36979	Now monitoring attacks.
Feb 21 15:25:20	php-fpm	395	/index.php: webConfigurator authentication error for user 'admin' from: 199.100.16.101
Feb 21 16:25:20	sshguard	36979	Attack from "199.100.16.101" on service unknown service with danger 10.
Feb 21 15:25:25	php-fpm	41615	/index.php: webConfigurator authentication error for user 'admin' from: 199.100.16.101
Feb 21 16:25:25	sshguard	36979	Attack from "199.100.16.101" on service unknown service with danger 10.
Feb 21 15:25:31	php-fpm	41615	/index.php: Successful login for user 'admin' from: 199.100.16.101 (Local Database)
Feb 21 16:44:24	sshd	47931	error: Fssh_kex_exchange_identification: Connection closed by remote host
Feb 21 16:44:24	sshd	47931	Connection closed by 12.110.206.207 port 34288
Feb 21 17:18:51	php-fpm	41615	/index.php: Successful login for user 'admin' from: 199.100.16.101 (Local Database)

1. ***The Fail2ban Status:*** *A screenshot of the command* `sudo fail2ban-client status sshd`*. This will show a "Banned IP list" containing the Red Team's IP addresses.*
2. ***OSSEC Alerts:*** *A screenshot of the OSSEC alerts log (*`/var/ossec/logs/alerts/alerts.log`*) showing* ***Level 10*** *alerts for "Multiple failed logins" followed by "IP address banned."*
3. ***Firewall Rejection:*** *A screenshot from the PFSense "Status > System Logs > Firewall" tab showing blocked packets on Port 22 from IPs that were previously attempting to connect.*

Conclusion on SSH: *The Red Team was unable to leverage the weak "TSI" passwords via SSH because our automated blocking mechanisms (Fail2ban) severed their connection before a successful brute-force or dictionary attack could complete. This effectively forced the attackers to seek alternative, unauthenticated entry points (such as the Webmin RCE and SQL Injection mentioned above).*